

Risk Register (multi-OS)

Registre des risques, incluant les risques multi-OS (Windows first-class, WinRM, btrfs, mapping agnostique). Voir aussi [risk-register.csv](#).

Risk Register

Id	Risk	Category	Likelihood	Impact	Severity	Mitigation	Owner	Status
RSK-01	GB/GiB rounding and unit drift in reports; values diverge from canonical bytes	Data Quality	Medium	Medium	Medium	Store and compute ALWAYS in bytes (schema invariant); round only at presentation layer; unit assertions in validation	Data Engineer	Open
RSK-02	Missing AIX golden image / reference standard; nothing to deviate against for rootvg/datavg/JFS2	Standards	Medium	High	High	Build AIX golden image early; layered inheritance (OS-family -> distro -> version -> role); flag hosts with no applicable standard	Standards Owner	Open
RSK-03	Inconsistent naming (VG/LV/mount/host) defeats grouping and standard matching	Data Quality	High	Medium	High	Normalization + canonical naming dictionary; fuzzy match with human confirmation; record raw + normalized	Data Engineer	Open

Id	Risk	Category	Likelihood	Impact	Severity	Mitigation	Owner	Status
RSK-04	False positives/negatives in deviation detection erode trust and hide real risk	Detection Accuracy	High	High	Critical	Calibrate thresholds per OS/fstype/role; severity tiers; human-in-the-loop on high-impact; precision/recall tracking on labeled set	ML/Detection Lead	Open
RSK-05	LLM hallucination (LangGraph agents invent mounts, standards, or remediations)	AI/Agentic	Medium	High	High	Ground every claim in collected JSON; constrained tool outputs; cite snapshot fields; deterministic checks gate LLM narrative	AI Lead	Open
RSK-06	Broken FS<->topology linkage (group_ref/backing_ref not resolving) breaks storage_class derivation	Schema Integrity	Medium	High	High	Referential-integrity validation on every snapshot; orphan-ref alerts; derive storage_class only when links resolve, else mark unknown	Data Engineer	Open
RSK-07	Single-snapshot view: no history -> no growth trend, no forecasting	Forecasting	High	High	Critical	Persist time-series of snapshots; require >=N points before forecasting; gate objectives 3/4 on history availability	Data Engineer	Open
RSK-08	Privacy / scope creep: collection captures sensitive content beyond metadata	Compliance	Low	High	High	Metadata-only contract; non-sensitive aggregates only; ACL summaries non-sensitive; review collection commands; DLP review	Security/Compliance	Open

Id	Risk	Category	Likelihood	Impact	Severity	Mitigation	Owner	Status
RSK-09	Command variance across OS versions yields inconsistent or unparseable output	Collection	High	Medium	High	Version-aware command matrix; parser per command/version; collection_method + scan_confidence recorded; fail-soft per field	Collection Eng	Open
RSK-10	Data volume at >=500 hosts x fields x snapshots overwhelms storage/processing	Scalability	Medium	Medium	Medium	One JSON doc/host; columnar/partitioned store for history; incremental processing; retention policy	Platform Eng	Open
RSK-11	Incomplete collection (host unreachable, partial scan) skews fleet view	Collection	High	Medium	High	scan_confidence + completeness flags; exclude partial from aggregates; retry/backfill; surface coverage metrics	Collection Eng	Open
RSK-12	Reference/standards drift: standards age and diverge from real fleet state	Standards	Medium	Medium	Medium	Versioned standards with effective dates; periodic review cadence; drift report standards-vs-fleet	Standards Owner	Open
RSK-13	Validation bottleneck: human review can't keep pace with fleet-scale deviations	Operational	Medium	Medium	Medium	Auto-triage by severity; batch low-risk; only high-impact to humans; feedback loop to tune thresholds	Operations Lead	Open
RSK-14	Data-at-rest security of the storage inventory (still infra-sensitive even if non-sensitive content)	Security	Low	High	High	Encrypt at rest; access control + audit; least privilege; segregate from production credentials	Security/Compliance	Open

Id	Risk	Category	Likelihood	Impact	Severity	Mitigation	Owner	Status
RSK-15	OS-landscape change (new distro/version/Windows build) outpaces collectors/standards	Maintainability	Medium	Medium	Medium	Pluggable collectors + standards; onboarding checklist for new OS; backlog SLA for new platforms	Platform Eng	Open
RSK-16	Over-reliance on automation: remediation acted on without human judgment	AI/Agentic	Medium	High	High	Human approval gate for changes; recommend-only mode by default; audit trail; clear automation boundaries	AI Lead	Open
RSK-17	Windows model divergence: no LVM; mapping NTFS volumes / Storage Spaces onto the agnostic schema (pool=group, virtual disk=volume, basic disk=>partitions-as-volumes + empty groups)	Schema Integrity	Medium	High	High	Explicit Windows mapping rules with *_kind discriminators; basic-disk path yields empty groups by design; conformance tests on real Windows snapshots; treat C:/BootDevice as system storage_class	Windows Platform Eng	Open
RSK-18	WinRM authentication & security: agentless reach needs credentials, encryption, and trusted transport to >=500 Windows hosts	Security	Medium	High	High	WinRM over HTTPS/Kerberos; vaulted least-privilege service account; no plaintext creds; per-host scoping; rotate + audit; network segmentation	Security/Compliance	Open

Id	Risk	Category	Likelihood	Impact	Severity	Mitigation	Owner	Status
RSK-19	BTRFS subvolume/snapshot size accounting: plain df is MISLEADING -> wrong used_percent and wrong forecasts on SLES/SUSE	Data Quality	High	High	Critical	Use 'btrfs filesystem usage' / qgroups for true bytes (never plain df on btrfs); fstype-aware collector branch; validate against allocated extents	Collection Eng	Open
RSK-20	Agnostic-schema mapping errors: group_ref/backing_ref semantics differ across AIX/Linux/Windows and get crossed	Schema Integrity	Medium	High	High	Per-platform mapping spec with key conventions; cross-platform referential-integrity tests; canonical ref namespace; reject ambiguous links	Data Engineer	Open
RSK-21	Standards explosion across OS x distro x version x role (combinatorial standard set)	Standards	High	Medium	High	Layered inheritance (defaults at OS-family, overridden down to role/version); only store deltas; inheritance-resolution tests	Standards Owner	Open
RSK-22	Windows ACL-summary vs Unix mount-options compliance-model mismatch (access_model differs: ntfs-acl vs posix-mount-options)	Compliance	Medium	Medium	Medium	Two compliance evaluators keyed on access_model; map intent (e.g., no-exec, restricted-write) to per-model checks; never apply mount-option rules to NTFS	Security/Compliance	Open

Id	Risk	Category	Likelihood	Impact	Severity	Mitigation	Owner	Status
RSK-23	Simultaneous multi-OS delivery (AIX + Linux distros + Windows all first-class, no phase 2) inflates scope and complexity	Delivery	High	High	Critical	Shared agnostic schema + pluggable per-OS collectors/standards; parallel workstreams with common contracts; staged enablement behind one schema; explicit MVP per objective on every OS	Program Lead	Open

Top risks & response

- RSK-04 (False positives/negatives) — Critical. Detection errors directly defeat objectives 1 and 5 and destroy operator trust. Response: per-OS/fstype/role threshold calibration, severity tiers, mandatory human-in-the-loop on high-impact deviations, and continuous precision/recall tracking against a labeled set before any auto-action.
- RSK-07 (Single-snapshot, no history) — Critical. Without time-series there is no growth trend, so objectives 3 (reliability/scalability) and 4 (forecasting) cannot be met. Response: persist a snapshot time-series from day one, require a minimum number of points before forecasting, and gate growth-dependent objectives on history availability.
- RSK-19 (BTRFS size accounting on SLES/SUSE) — Critical. Plain df on btrfs with subvolumes/snapshots reports wrong bytes, corrupting used_percent and every downstream forecast and deviation. Response: fstype-aware collector that uses 'btrfs filesystem usage'/qgroups (never plain df), validated against allocated extents.
- RSK-23 (Simultaneous multi-OS delivery) — Critical. Delivering AIX, all Linux distros, and Windows as first-class at once, with no phase 2, multiplies scope and integration risk. Response: anchor everything on the single agnostic schema with pluggable per-OS collectors and standards, run parallel workstreams against common contracts, and define an explicit MVP per objective on every OS.
- RSK-17 / RSK-18 / RSK-22 (Windows first-class set) — High. Windows joins now at full depth: schema mapping (no LVM, Storage Spaces -> groups/volumes), agentless WinRM security, and a distinct ACL-based compliance model. Response: explicit Windows mapping rules with conformance tests, WinRM over HTTPS/Kerberos with vaulted least-privilege accounts, and a separate compliance evaluator keyed on access_model so NTFS ACL intent is never judged by POSIX mount-option rules.

- RSK-02 / RSK-21 (Standards coverage and explosion) — High. Missing reference images (notably AIX) mean nothing to deviate against, while the OS x version x role matrix risks a combinatorial standards blow-up. Response: build golden images early and tame combinatorics with layered inheritance, storing only deltas from OS-family defaults down to role/version.
- RSK-05 / RSK-16 (LLM hallucination and over-automation) — High. Agentic LangGraph reasoning can invent facts or act without judgment. Response: ground every assertion in collected JSON with deterministic checks gating the LLM narrative, default to recommend-only mode, and require a human approval gate with full audit trail before any remediation.